

Password Strength Assessment using Active Online Attacks

Tool: John the Ripper

Theory

John the Ripper is an open-source password security auditing tool used to test the strength of password hashes. It works by generating candidate passwords, hashing them, and comparing the result against stored hashes. It supports dictionary attacks, brute-force attacks, and rule-based attacks. This experiment is performed on a locally created test file in Kali Linux to assess weak password risks.

Steps

1. Open the terminal in Kali Linux. Verify John the Ripper is installed. Run: `john --version` — If not installed, run: `sudo apt install john -y`
 2. Decompress the rockyou wordlist which is included in Kali Linux. Run: `sudo gunzip /usr/share/wordlists/rockyou.txt.gz` — This file contains over 14 million commonly used passwords.
 3. Create a test password hash file to simulate a real scenario. First create a local user. Run: `sudo useradd -M testuser` — Then set a weak password. Run: `echo 'testuser:password123' | sudo chpasswd`
 4. Extract the password hash for the test user from the shadow file. Run: `sudo grep testuser /etc/shadow > /tmp/test_hash.txt` — View the hash. Run: `cat /tmp/test_hash.txt`
 5. Run a dictionary attack on the hash file using the rockyou wordlist. Run: `john --wordlist=/usr/share/wordlists/rockyou.txt /tmp/test_hash.txt` — John will start trying passwords from the wordlist against the stored hash.
 6. View the cracked password. Run: `john --show /tmp/test_hash.txt` — The output shows the username and the cracked plaintext password.
 7. To test with a specific hash format, run: `john --format=md5crypt --wordlist=/usr/share/wordlists/rockyou.txt /tmp/test_hash.txt`
 8. To apply mangling rules that try variations like adding numbers or capitalising letters, run: `john --wordlist=/usr/share/wordlists/rockyou.txt --rules /tmp/test_hash.txt`
 9. Clean up after the experiment. Remove the test user and hash file. Run: `sudo userdel testuser` then: `rm /tmp/test_hash.txt`
-

Conclusion

John the Ripper successfully cracked the weak test password using a dictionary attack with the rockyou wordlist. This demonstrates that simple passwords are highly vulnerable and highlights the importance of enforcing strong password policies in any system.